

MODULE 3 OSI Model & Protocol Security

Phase	Duration
Phase 1	Week 2

Module Overview

This module deepens the networking knowledge established in Module 2 by introducing the OSI (Open Systems Interconnection) reference model the universal framework used by security professionals worldwide to describe, diagnose, and defend network communications. We will learn to map every protocol, attack technique, and security control to a specific OSI layer, which is an essential skill for understanding how and where breaches occur.

Rather than focusing on tools, this module builds strong conceptual understanding of how protocols behave, where they are vulnerable, and what security controls operate at each layer. This mental model is foundational for all later modules covering monitoring, incident response, and ethical hacking.

Learning Objectives

By the end of this module, we will be able to:

- Describe the seven layers of the OSI model and the role each layer plays in network communication
- Explain how data is encapsulated as it travels down the OSI stack and de-encapsulated as it travels up
- Map common network protocols to their correct OSI layer
- Identify which OSI layer common attack types target
- Compare the OSI model to the TCP/IP model and explain the relationship between them
- Describe the security controls and defensive mechanisms relevant to each OSI layer
- Explain the role of encryption at different layers and why it matters for data confidentiality
- Analyse a described attack scenario and identify the OSI layer being exploited

Why the OSI Model Matters for Security

The OSI model was developed by the International Organization for Standardization (ISO) in 1984 as a conceptual framework for standardizing network communication. While real-world networks use the TCP/IP stack in practice, the OSI model remains the universal language of network security because it provides a precise, shared vocabulary for locating problems and attacks.

The Security Professional's Perspective

When a security analyst says "this is a Layer 2 attack" or "the vulnerability exists at Layer 7," they are using OSI terminology to precisely locate where a problem occurs. Certifications such as CompTIA Security+, CEH, and CISSP all test OSI knowledge extensively. Incident reports, vendor documentation, and security research all reference OSI layers fluency in this model is non-negotiable for any cybersecurity professional.

Three Key Security Benefits of Knowing the OSI Model:

- **Pinpoint attacks:** Knowing which layer an attack targets tells you exactly what component to inspect, patch, or monitor
- **Select controls correctly:** Firewalls, encryption, IDS, and VLANs each operate at specific OSI layers; deploying them correctly requires understanding this
- **Communicate precisely:** Security teams, vendors, and auditors share a common vocabulary, reducing miscommunication during incidents

The Seven Layers of the OSI Model

The OSI model divides network communication into seven distinct layers, each with a specific responsibility. Data travels down the stack on the sending side (encapsulation) and up the stack on the receiving side (de-encapsulation).

A useful mnemonic for the layers top-to-bottom is:

"All People Seem To Need Data Processing."

Layer 7 → Layer 6 → Layer 5 → Layer 4 → Layer 3 → Layer 2 → Layer 1
Application → Presentation → Session → Transport → Network → Data Link → Physical

Layer	Name	One-Line Role
7 – Application	Application	Interface between the network and end-user applications
6 – Presentation	Presentation	Data formatting, encryption, compression, and translation
5 – Session	Session	Establishes, manages, and terminates communication sessions

4 – Transport	Transport	End-to-end delivery, error checking, and flow control
3 – Network	Network	Logical addressing and routing of packets between networks
2 – Data Link	Data Link	Node-to-node delivery using MAC addresses within a LAN
1 – Physical	Physical	Transmission of raw bits over a physical medium

Layer-by-Layer Detail

Layer 7: Application Layer

The Application layer is the topmost layer and the one that end users interact with directly. It provides network services to applications such as web browsers, email clients, and file transfer programs. This is where human-readable data originates before it is packaged for transmission.

Key Protocols at Layer 7:

Protocol	Purpose & Security Notes
HTTP / HTTPS	Web communication. HTTP transmits data in plaintext — always prefer HTTPS which adds TLS encryption to protect data in transit.
DNS	Translates domain names to IP addresses. DNS queries are often unencrypted and can be intercepted or spoofed (DNS poisoning).
SMTP / POP3 / IMAP	Email sending and retrieval. Unencrypted versions expose email content and credentials — TLS variants (SMTPS, IMAPS) should always be used.
FTP / SFTP	File transfer. Plain FTP sends credentials and data in cleartext. SFTP (over SSH) provides encryption and must always be preferred.
DHCP	Automatically assigns IP configuration to devices. Can be abused by rogue DHCP servers to redirect network traffic.
SNMP	Manages and monitors network devices. Older versions (v1, v2) have weak authentication — SNMPv3 with encryption is required.

Common Layer 7 Attacks:

- **Phishing:** Fraudulent emails or web pages impersonating trusted services to harvest credentials
- **SQL Injection:** Malicious database queries injected through web application input fields
- **Cross-Site Scripting (XSS):** Injecting malicious scripts into web pages viewed by other users
- **DNS Spoofing:** Poisoning DNS responses to redirect users to attacker-controlled sites
- **Application-layer DDoS:** Flooding a web server with legitimate-looking HTTP requests (e.g. HTTP flood)

Layer 7 Security Controls:

- **Web Application Firewalls (WAF):** Filter and monitor HTTP traffic to block injection and scripting attacks
- **Input validation and sanitization:** Prevent injection attacks by rejecting unexpected input at the application level
- **TLS/SSL encryption:** Encrypts application data in transit, protecting confidentiality and integrity
- **Strong authentication:** Multi-factor authentication (MFA) reduces the impact of credential theft

Layer 6: Presentation Layer

The Presentation layer acts as the translator between the application and the network. It is responsible for data formatting, character encoding, compression, and encryption/decryption. Its job is to ensure that data sent by one system can be understood by the receiving system regardless of internal differences.

Core Responsibilities:

Function	Explanation & Security Relevance
Data Formatting	Converts data between formats (e.g. ASCII, Unicode, EBCDIC) so different systems can communicate correctly
Encryption & Decryption	TLS/SSL operates here, encrypting data before transmission and decrypting it on receipt the primary mechanism protecting data confidentiality
Compression	Reduces the size of data for efficient transmission. Compression-based attacks like CRIME exploit TLS compression to extract encrypted data
Data Translation	Converts between different data representations (e.g. big-endian vs little-endian byte order)

Security Significance:

Most encryption relevant to web and email security operates at or across the Presentation and Application layers. Understanding that TLS provides confidentiality at this layer explains why HTTPS traffic cannot be read by network observers but also why endpoints (not just the network) must be secured, since decryption happens at the receiving application.

- **SSL Stripping:** An attacker downgrades a connection from HTTPS to HTTP, exposing plaintext data; prevented by HTTP Strict Transport Security (HSTS)
- **Weak Cipher Suites:** Outdated encryption algorithms (DES, RC4, old TLS versions) can be broken; organisations must enforce modern cipher standards

Layer 5: Session Layer

The Session layer manages the establishment, maintenance, and termination of communication sessions between two devices. Think of a session as the entire conversation between two parties the Session layer opens the conversation, keeps it organised, and closes it gracefully when finished.

Core Responsibilities:

Function	Explanation
Session Establishment	Negotiates and creates a communication session between two systems, including any authentication required to open the session
Session Maintenance	Keeps the session active during data transfer, handles synchronisation checkpoints, and manages dialogue control
Session Termination	Cleanly closes the session when communication is complete, releasing resources on both sides
Authentication	Some authentication mechanisms operate at this layer, verifying identity before a session is permitted to continue

Common Layer 5 Attacks:

- **Session Hijacking:** An attacker steals or forges a valid session token to impersonate an authenticated user without needing their password
- **Session Fixation:** The attacker forces a user to authenticate with a session ID the attacker already knows, enabling immediate takeover
- **Replay Attacks:** Capturing and retransmitting valid session data to repeat a previous authenticated action

Defensive Controls:

- **Secure session token generation:** Use long, random, unpredictable session IDs that cannot be guessed
- **Session expiry:** Short session timeouts limit the window of opportunity for session hijacking
- **Token binding:** Bind session tokens to specific client attributes (IP, user agent) to make stolen tokens useless

Layer 4: Transport Layer

The Transport layer provides end-to-end communication between applications, managing how data is divided into segments, how delivery is verified, and how errors are corrected. It is the layer where port numbers live, enabling multiple applications on the same device to communicate simultaneously.

TCP vs. UDP at Layer 4:

Aspect	Description
TCP (Transmission Control Protocol)	Connection-oriented protocol providing reliable, ordered delivery with error correction. Uses the three-way handshake (SYN, SYN-ACK, ACK) to establish connections.
UDP (User Datagram Protocol)	Connectionless protocol prioritising speed over reliability. No handshake, no guaranteed delivery — used for real-time applications where some packet loss is acceptable.
Port Numbers	Layer 4 uses port numbers (0–65535) to direct traffic to the correct application. Well-known ports (0–1023) are assigned to standard services.
Segmentation & Reassembly	Large messages are broken into smaller segments for transmission and reassembled at the destination — a process that can be exploited by fragmentation attacks.

Common Layer 4 Attacks:

- **SYN Flood:** Sending thousands of TCP SYN packets without completing the handshake, exhausting the server's connection table (classic DoS attack)
- **Port Scanning:** Systematically probing a target's ports to discover open services and potential vulnerabilities (a reconnaissance technique)
- **Session Hijacking via Sequence Prediction:** Predicting TCP sequence numbers to inject forged packets into an established connection
- **UDP Flood:** Overwhelming a target with high-volume UDP packets to exhaust bandwidth and processing capacity

Layer 4 Security Controls:

- **Stateful firewall inspection:** Tracks the state of TCP connections and blocks packets that don't match a known connection state
- **Rate limiting:** Restricts the number of connection attempts from a single source, mitigating brute force and flood attacks
- **Port filtering:** Block unused ports at the firewall to reduce the attack surface exposed to the Internet

Layer 3: Network Layer

The Network layer is responsible for logical addressing and routing determining the best path for packets to travel from source to destination across multiple networks. IP addresses operate at this layer, and routers are the primary Layer 3 devices.

Core Responsibilities:

Function	Explanation & Security Relevance
Logical Addressing	IP addresses (IPv4 and IPv6) uniquely identify devices across internetworks and are assigned at this layer
Routing	Routers examine destination IP addresses and consult routing tables to forward packets toward their destination via the most efficient path
Packet Fragmentation	Large packets may be fragmented to fit within network MTU limits — attackers can exploit fragmentation to bypass security controls
ICMP	Internet Control Message Protocol provides error reporting and diagnostics (e.g. ping). ICMP can be abused for reconnaissance and tunneling

Common Layer 3 Attacks:

- **IP Spoofing:** Forging the source IP address in packet headers to impersonate another host or mask the attacker's location
- **ICMP Tunneling:** Encoding malicious data inside ICMP packets to create a covert communication channel that bypasses firewalls
- **Routing Table Poisoning:** Injecting false routing information to redirect traffic through attacker-controlled paths (BGP hijacking at internet scale)
- **Smurf Attack:** Sending ICMP echo requests with a spoofed victim IP to a broadcast address, causing all hosts to reply to the victim simultaneously (amplification DoS)

Layer 3 Security Controls:

- **Network-layer firewalls:** Filter traffic based on source/destination IP addresses and protocols
- **Ingress/Egress filtering:** ISPs and organisations drop packets with spoofed or impossible source addresses at network boundaries
- **IPsec:** Internet Protocol Security provides encryption and authentication at the Network layer, protecting IP packet confidentiality and integrity
- **Private addressing and NAT:** Conceals internal IP addresses from external observers, reducing direct exposure of internal systems

Layer 2: Data Link Layer

The Data Link layer governs node-to-node communication within the same network segment. It uses MAC (Media Access Control) addresses hardware addresses burned into network interface cards to identify devices on the local network. Switches are the primary Layer 2 devices.

Key Concepts:

Concept	Explanation
MAC Address	A 48-bit hardware address (e.g. 00:1A:2B:3C:4D:5E) unique to each network interface. Used for local delivery within a network segment.
Frames	Data Link layer encapsulates packets from Layer 3 into frames — the unit of transmission at this layer — adding MAC address headers and trailers for error detection.
ARP	Address Resolution Protocol maps IP addresses to MAC addresses within a local network. ARP has no authentication, making it vulnerable to spoofing.
VLANs	Virtual LANs segment a physical network into isolated logical networks. Properly configured VLANs prevent devices in one segment from communicating directly with another.
Switches	Forward frames based on MAC addresses, creating dedicated connections between sender and receiver. Much more secure than hubs, which broadcast all traffic to all ports.

Common Layer 2 Attacks:

- **ARP Spoofing / ARP Poisoning:** Sending forged ARP replies to associate the attacker's MAC address with a legitimate IP, redirecting all traffic through the attacker (enables man-in-the-middle attacks)
- **MAC Flooding:** Overwhelming a switch's MAC address table with fake entries, causing it to fail open and broadcast all traffic like a hub enabling passive eavesdropping
- **VLAN Hopping:** Exploiting misconfigured trunk ports using double-tagging to send traffic into a VLAN the attacker should not have access to
- **MAC Spoofing:** Changing a device's MAC address to impersonate another device and bypass MAC-based access controls

Layer 2 Security Controls:

- **Dynamic ARP Inspection (DAI):** DAI is a switch security feature that blocks fake ARP messages to prevent ARP spoofing attacks.
- **Port Security on Switches:** Port security on a switch limits which devices (MAC addresses) can connect to a port, helping prevent unauthorized access.
- **VLAN segmentation:** VLAN segmentation divides one physical network into separate virtual networks to isolate traffic and improve security and performance.

Layer 1: Physical Layer

The Physical layer is the foundation of the OSI model, responsible for the actual transmission of raw binary data (bits) over a physical medium such as copper cables, fiber optic cables, or radio waves. It defines the electrical, optical, and mechanical specifications of the medium.

Physical Media Types:

Medium	Characteristics & Security Considerations
Copper (Ethernet / Cat6)	Transmits electrical signals. Susceptible to electromagnetic interference and physical tapping. Must be protected by physical access controls.
Fiber Optic	Transmits light pulses. Extremely difficult to tap without detection. Immune to electromagnetic interference preferred for high-security and long-distance links.
Wireless (Wi-Fi / Radio)	Transmits radio waves through the air. Anyone within range can receive the signal requires strong encryption (WPA3) and authentication to prevent eavesdropping.
Bluetooth / NFC	Short-range wireless technologies. Vulnerable to bluejacking, bluesnarfing, and eavesdropping if improperly configured or left discoverable.

Common Layer 1 Attacks:

- **Physical Wiretapping:** Physically connecting to a cable to intercept raw network signals (most relevant for copper; very difficult for fiber)
- **Jamming:** Transmitting interference signals on wireless frequencies to disrupt communications (wireless DoS)
- **Unauthorized Device Connection:** Plugging an unauthorized device into a physical network port to gain unauthenticated network access
- **Hardware Key loggers:** Physical devices inserted between a keyboard and computer to capture keystrokes a Layer 1 data theft technique

Layer 1 Security Controls:

- **Physical access controls:** Locked server rooms, cable management, port locks, and CCTV prevent unauthorized physical access to network infrastructure
- **Disable unused ports:** Switch ports with no connected devices should be administratively disabled to prevent rogue device connections
- **Fiber optic for sensitive links:** Use fiber for high-security inter-building or data Centre connections where tapping risk must be minimized
- **Wireless encryption:** Wireless encryption is a security method that scrambles Wi-Fi data so only authorized users with the correct key can read it.

OSI Model vs. TCP/IP Model Comparison

Students often encounter both models and need to understand how they relate. The TCP/IP model is what real networks actually implement; the OSI model is the conceptual framework used for analysis and communication.

OSI Layer	TCP/IP Layer	Relationship
7 – Application	Application	All three OSI application layers (7, 6, 5) map to a single TCP/IP Application layer
6 – Presentation	Application	Encryption, formatting, and translation handled within the TCP/IP Application layer
5 – Session	Application	Session management functions absorbed into TCP/IP's Application layer
4 – Transport	Transport	Direct mapping — TCP and UDP operate at this layer in both models
3 – Network	Internet	IP addressing and routing — direct mapping (called Internet layer in TCP/IP)
2 – Data Link	Network Access	Both Data Link and Physical map to TCP/IP's Network Access layer
1 – Physical	Network Access	Physical transmission handled within TCP/IP's Network Access layer

Which Model Do Security Professionals Use?

Both but in different contexts. The OSI model is used for analysis, troubleshooting, vendor documentation, and certifications because its seven layers provide a more granular vocabulary. The TCP/IP model is used when discussing actual protocol implementation and network engineering. A security analyst must be comfortable translating between both.

Data Encapsulation & De-encapsulation

Understanding encapsulation is essential because it explains how data is protected and identified as it moves through the network. At each layer, a header (and sometimes trailer) is added that contains control information for that layer. This process is called encapsulation. At the receiving end, each layer strips off its header a process called de-encapsulation.

Encapsulation: when data is sent, each network layer **adds its own “information (wrapper)”** to help deliver it (like IP address, MAC address, ports).

Decapsulation: when data is received, each layer **removes those wrappers one by one** to reveal the original data.

OSI Layer	Protocol Data Unit (PDU) & What Gets Added
Layer 7 – Application	Data - The original message or request from the user or application
Layer 6 – Presentation	Data - Encrypted, formatted, or compressed as required
Layer 5 – Session	Data - Session identifiers added to track the conversation
Layer 4 – Transport	Segment - TCP/UDP header added: source port, destination port, sequence number, flags
Layer 3 – Network	Packet - IP header added: source IP, destination IP, TTL, protocol
Layer 2 – Data Link	Frame - MAC header added: source MAC, destination MAC; trailer includes error-check (CRC)
Layer 1 – Physical	Bits - Frame converted to electrical signals, light pulses, or radio waves for transmission

Why Encapsulation Matters for Security:

- **Each header reveals information:** Source/destination IPs, ports, and MACs can be analyzed for suspicious patterns by security tools
- **Headers can be forged:** IP spoofing and ARP spoofing both involve manipulating headers that other layer's trust
- **Encryption protects payloads not headers:** Encryption protects the payload (data) by making it unreadable, while leaving the header visible so the network can deliver it correctly. TLS encrypts the data payload but leaves IP and TCP headers visible; this is why metadata analysis (traffic analysis) can still reveal communication patterns
- **Deep Packet Inspection (DPI):** Security devices can inspect headers at every layer to detect anomalies, malware signatures, or policy violations.

DPI (Deep Packet Inspection) is a network security technique that examines the **actual data inside packets (payload)** to detect threats, filter traffic, or enforce policies.

Attack-to-Layer Reference Table

One of the most practical uses of the OSI model is quickly mapping attack types to the layers they target. This guides incident response and helps analysts identify which controls should have prevented the attack.

Attack Type	OSI Layer Targeted	Brief Explanation
Phishing / Social Engineering	Layer 7 – Application	Exploits application-layer protocols (email, web) to deceive users
SQL Injection	Layer 7 – Application	Injects malicious queries through web application input fields

Cross-Site Scripting (XSS)	Layer 7 – Application	Injects scripts into web pages served to other users via HTTP
SSL Stripping	Layer 6 – Presentation	Downgrades HTTPS connections to unencrypted HTTP
Session Hijacking	Layer 5 – Session	Steals session tokens to impersonate authenticated users
SYN Flood	Layer 4 – Transport	Exhausts server resources with incomplete TCP handshakes
Port Scanning	Layer 4 – Transport	Probes TCP/UDP ports to identify open services
IP Spoofing	Layer 3 – Network	Forges source IP addresses to hide identity or impersonate hosts
ICMP Tunnelling	Layer 3 – Network	Embeds covert data within ICMP echo packets
ARP Spoofing	Layer 2 – Data Link	Poisons ARP cache to redirect LAN traffic through attacker
MAC Flooding	Layer 2 – Data Link	Overwhelms switch MAC table, forcing hub-like broadcast behaviour
Physical Wiretapping	Layer 1 – Physical	Directly taps cables to intercept raw electrical or optical signals
Jamming	Layer 1 – Physical	Transmits interference to disrupt wireless communications

Additional Resources & Reading

Recommended Reading

- **CompTIA Network+ Study Guide by Mike Meyers** – Covers OSI and TCP/IP models in depth with clear, beginner-friendly explanations
- **Computer Networking: A Top-Down Approach by Kurose & Ross** – The gold-standard textbook for understanding protocol layers and their behaviour
- **The OSI Model Demystified by Craig Zacker** – Concise reference specifically focused on the OSI model for networking students

Online Resources

- Cloudflare Learning: What is the OSI Model? — <https://www.cloudflare.com/learning/ddos/glossary/open-systems-interconnection-model-osi/>
- Cisco OSI Model Overview — <https://www.cisco.com/c/en/us/support/docs/wireless-mobility/wireless-lan-wlan/13727-6.html>
- Professor Messer – OSI Model (free video) — <https://www.professormesser.com>

- NIST Glossary of Security Terms — <https://csrc.nist.gov/glossary>

Concept Reinforcement

- Draw the OSI stack from memory every day until you can do it without notes — layer number, name, key protocol, and one attack per layer
- Practice mapping attack scenarios: read any cybersecurity news article and identify which OSI layer(s) the described attack targets
- Create your own flashcard set for all seven layers, their PDUs, key protocols, common attacks, and defensive controls